



# Informe de Ciberseguridad

# Rating

## ¿Qué te ofrece este servicio?

A través del informe de ciberseguridad podrás conocer el nivel real de exposición al que se encuentra tu organización frente a los ataques cibernéticos.

## ¿Cómo es posible?

Gracias a las avanzadas herramientas utilizadas para elaborar este informe, sabrás cuántos de tus activos se encuentran en peligro, y cuáles son las mejores prácticas para protegerlos.



A dark blue background featuring a faint world map. Overlaid on the map are numerous red circles of varying sizes, representing data points or locations. The circles are most concentrated in the Americas, Europe, and parts of Asia, with some scattered points in Africa and Australia.

# Datos principales

## 1. Resumen

### \*\*em\*.com

#### Alcance

Este informe de Ciberseguridad ha sido elaborado con fecha 30-01-2023. Refleja una instantánea del estado de seguridad de la organización basado en criterios técnicos tras una fase de descubrimiento y análisis. La fase de descubrimiento trata de obtener de forma desatendida una foto lo más fidedigna posible de activos de la organización expuestos a internet. Tras el descubrimiento se realizan una serie de pruebas y comprobaciones de seguridad no intrusivas cuya finalidad es detectar fallos y mejoras de seguridad que puedan ayudar a su organización a mejorar desde un punto de vista técnico el riesgo y la forma en la que sus activos están expuestos a internet.

#### Dominio de partida

A continuación se muestra el dominio usado como punto de partida para el descubrimiento del perímetro de su organización. El resto de direcciones IP y dominio presentados en este informe son resultado de un descubrimiento automatizado del perímetro de su organización que tiene como punto de partida este dominio.

[\\*\\*em\\*.com](#) |

#### Rating

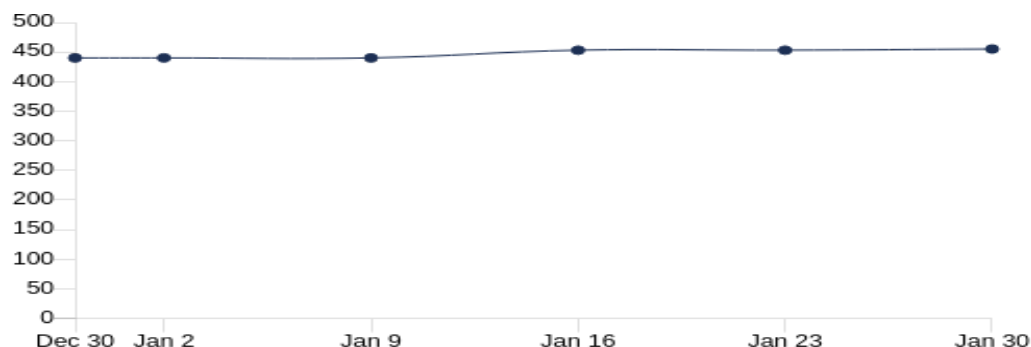
Los indicadores presentados a continuación ofrecen una métrica del nivel de exposición de su organización ante ataques cibernéticos, y han sido obtenidos a partir de la información recabada durante el proceso de análisis técnico llevado a cabo para la elaboración de este informe. En esta sección se presentan dos indicadores:

#### Score Global de la organización: 455

Este indicador es un valor numérico cuya escala va desde 1 (exposición muy elevada ante ataques cibernéticos) a 1.000 (exposición reducida). Un aumento de valor de este indicador es sinónimo de mejora en algún parámetro técnico con impacto positivo en el nivel de ciberseguridad de la organización respecto al último análisis.

#### Evolución

En la siguiente gráfica se puede observar la evolución a lo largo del tiempo de los valores de la métrica rating obtenido en cada uno de los análisis realizados. Esta gráfica permite ver la tendencia a lo largo del tiempo de las medidas técnicas que su empresa puede realizar para mejorar su nivel de seguridad.



El valor del rating para la compañía permite obtener una visión rápida de la evolución del nivel de riesgo y entender si es necesario o no realizar nuevas acciones para mejorar o mantener las actuales.

## 2. Activos

### Activos asociados

A continuación se detalla la distribución de los activos de la compañía y el estado de los mismos respecto a su nivel de riesgo. Un activo puede ser una dirección IP o un dominio, en definitiva, algo que puede ser objeto de ataque por cualquier amenaza procedente de internet. En la primera columna se puede observar un resumen de la cantidad de activos por tipo descubierto.

El indicador del centro presenta el porcentaje del total de activos que está afectado por al menos una ocurrencia de seguridad. Esta métrica ayuda a visualizar qué porcentaje de activos que pueden estar en una situación de riesgo potencial.

Por último, a la derecha, puede observar una columna con el porcentaje de activos que están afectados por ocurrencias de seguridad críticas, altas, medias o bajas. Esta información pretende poner el foco del lector en los activos que presentan fallos de seguridad de mayor importancia.

### Activos (1053)

v4 IP4 (49)

v6 IP6 (27)

www Dominios (977)



Criticas: 0 Activos (0%)

Altas: 2 Activos (0%)

Medias: 26 Activos (2%)

Bajas: 91 Activos (8%)

Info: 83 Activos (7%)

### Distribución geográfica

Los activos asociados a la compañía se muestran geolocalizados de forma que se tenga una visión del alcance que tiene la huella digital de la organización a nivel mundial.



### 3. Resumen de criticidad de ocurrencias encontradas

A continuación se presenta un resumen de fallos u ocurrencias de seguridad detectados en los activos de su organización clasificados por nivel de riesgo. El nivel de riesgo está determinado por la facilidad potencial de que un atacante pueda aprovechar este fallo para lanzar un ataque y por el impacto que pueda tener la explotación de esa vulnerabilidad. Más detalles en la sección “Metodología” de este informe.

#### Criticidad de las ocurrencias encontradas en todos los activos

168 INFO

346 BAJAS

30 MEDIAS

1 ALTAS

0 CRITICAS

#### Distribución de criticidad por categoría en todos los activos. Total ocurrencias: (545)

En la siguiente agrupación se muestra el número de fallos u ocurrencias de seguridad detectados en cada uno de los grupos de pruebas de seguridad que se han efectuado sobre los activos de su organización. Siguiendo una metodología de análisis no intrusivo se realiza una batería de pruebas de seguridad a distintos niveles que se agrupan por nivel funcional. De esta forma, se pretende visualizar en qué parte de su infraestructura y aplicativos los recursos técnicos de su organización puede requerir más atención para aplicar mejoras de seguridad.

Puertos inseguros abiertos 1 ALTAS

Problemas de seguridad Web 26 MEDIAS 293 BAJAS 168 INFO

Cifrado inseguro 4 MEDIAS

Reputacion 1 BAJAS

Red 1 BAJAS

Problemas de seguridad en el DNS 47 BAJAS

Protección de marca 4 BAJAS

## 4. Recomendaciones de mejora con mayor impacto

En esta sección se propone a su organización diversas medidas técnicas de mejora para solucionar las ocurrencias o fallos de seguridad que se consideran más prioritarios de solucionar. Esta sección solo pretende ser una orientación apoyada en los parámetros de número de activos afectados sobre el perímetro y la criticidad de los fallos detectados. Se ofrece información sobre una vulnerabilidad que al mitigarse su nivel de riesgo mejora de forma más significativa en cuanto al score total se refiere.

### 1ª Opción de mejora

A continuación se ofrece una propuesta de mejora del nivel de seguridad realizada tras el análisis de todas las ocurrencias detectadas y presentadas en este informe. Esta propuesta es el resultado de una priorización efectuada en función de la mayor mejora potencial que se puede obtener sobre el score de seguridad actual de la organización.

#### **VULNERABILIDADES FRONT - LIBRERÍA JAVASCRIPT DESACTUALIZADA**

**24 activos afectados**

##### **Criticidad**

Alta

##### **Descripción**

A continuación se muestra un listado de vulnerabilidades detectadas sobre las librerías front obtenido durante el análisis junto con un enlace a la publicación de esta vulnerabilidad con el detalle de las mismas.

##### **Remediación**

Se recomienda actualizar a la última versión disponible de la librería afectada para un parcheo adecuado



# Problemas y soluciones en detalle



## Puertos inseguros abiertos

### Descripción

Durante el análisis realizado en los distintos módulos incluidos en esta categoría de pruebas se trata de detectar puertos TCP o UCP abiertos en algún activo de la organización que pudieran suponer un riesgo de seguridad. Esta situación suele suceder por una incorrecta aplicación de las políticas de filtrado de red de los elementos expuestos a internet. Los motivos por los que se considera que un puerto abierto puede incrementar el riesgo de seguridad son varios:

- Puertos relacionados con servicios que únicamente deben estar accesibles desde una red local (NFS, SMB, etc.)
- Puertos relacionados con la gestión por parte de administradores (SSH, Remote Desktop, etc.)
- Puertos de servicios de bases de datos
- Puertos relacionados con servicios que no ofrecen capa de cifrado por defecto.
- etc

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 1

Servicios de protocolo LAN expuesto.



### Recomendaciones

Siempre se debe seguir el principio de limitar al máximo el acceso de este tipo de servicios desde Internet. En caso de ser imprescindible para el correcto funcionamiento de los servicios que requieren los aplicativos es necesario utilizar redes privadas (VPN) para su acceso o en su defecto filtrados a nivel de red y/o sistema extremadamente restrictivos.

### Regulaciones



**El Reglamento General de Protección de Datos (GDPR) (Reglamento 2016/679)** es un reglamento por el que el Parlamento Europeo, el Consejo de la Unión Europea y la Comisión Europea tienen la intención de reforzar y unificar la protección de datos para todos los individuos dentro de la Unión Europea (UE). Para dar cumplimiento al reglamento es necesario la implementación de ciertos mecanismos de seguridad sobre los datos que manejan los sistemas de las compañías.

Entre los principales mecanismos de protección de los datos se encuentran el cifrado de la información que se intercambia con los usuarios a través de los diferentes métodos implementados para tal efecto. La no exposición en internet de sistemas que puedan contener o gestionar datos como por ejemplo bases de datos o repositorios de información. Evitar servicios de gestión de las plataformas accesibles sin ningún tipo de control perimetral. Implementar una gestión de versiones y parcheos sobre el software que se utilice de forma que no se permita el uso de software con vulnerabilidades.

## Servicios de protocolo LAN expuesto.

### Descripción detallada



Detectados servicios de protocolo de red local expuestos a la red de Internet. Este tipo de servicios deben de estar solamente accesibles desde las redes internas y no desde Internet.  
Port number: 2053

### Recomendacion



Limite el acceso de este tipo de servicios desde Internet. En caso de ser imprescindible para el correcto funcionamiento del negocio es necesario utilizar redes privadas (VPN) para su acceso o en su defecto filtrados a nivel de red y/o sistema extremadamente restrictivos.

### Activos afectados

| IP                   | DOMINIO   | PUERTO     | ÚLTIMO CHEQUEO   |
|----------------------|-----------|------------|------------------|
| 2606:4700::****.**** | **em*.com | 2053 / tcp | 29-01-2023 16:56 |

## Problemas de seguridad Web

### Descripción

Esta categoría de pruebas de seguridad está orientada a detectar ocurrencias de seguridad en cualquier servicio o aplicación web descubierto en el perímetro de la organización. Las aplicaciones web exponen en muchas ocasiones la mayoría de las funcionalidades que se exponen a los usuarios que consumen los servicios a través de internet. Pero al mismo tiempo, por ese mismo motivo, pueden presentar multitud de fallos de seguridad a nivel de código o configuración que pueden estar siendo expuestos a cualquier atacante situado en internet. Es de vital importancia revisar cualquier ocurrencia de seguridad detectada en esta categoría con el fin de analizar el impacto de estas y evaluar su consecuente corrección o mitigación. A continuación se muestran las subcategorías de pruebas y el resumen del nivel de seguridad de cada una de ellas que se han ejecutado dentro de este marco de pruebas y que presentan alguna ocurrencia detectada sobre los activos de la organización.

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 487

|                                                           |                                                                                      |     |
|-----------------------------------------------------------|--------------------------------------------------------------------------------------|-----|
| Listado de directorios                                    |    | 26  |
| Protección de cabeceras contra Clickjacking deshabilitada |   | 77  |
| Configuración insegura de HSTS                            |  | 44  |
| Cabecera de seguridad XSS deshabilitada                   |  | 103 |
| Conexiones HTTP inseguras                                 |  | 69  |
| Cabecera HTTP de plataforma habilitada                    |  | 125 |
| Cabecera HTTP Server detectada                            |  | 43  |

### Recomendaciones

Se recomienda siempre prestar atención a la configuración de los problemas que aplican a la seguridad de los servicios web ya que son el primer punto de atención que las amenazas de internet tienen sobre los servidores expuestos. Cada ocurrencia de seguridad debe ser analizada para minimizar el riesgo y el potencial punto de fallo que acabe desembocando en ataques más elaborados y con mayor impacto.

## Listado de directorios

### Descripción detallada



Se ha detectado que es posible realizar listado de directorio de forma inapropiada. Esto puede provocar que información potencialmente confidencial o sensible pueda estar accesible para los atacantes.

Los riesgos y consecuencias específicos varían según los archivos que se enumeran y sean accesibles mediante esta debilidad.

### Recomendación



Algunos ejemplos de cómo configurar los servidores para no permitir el listado de directorios:

Servidor web Apache

Deshabilitar la lista de directorios configurando la directiva Options en el archivo httpd.conf de Apache agregando la siguiente línea:

```
<Directory /your/website/directory>Options -Indexes</Directory>
```

También puede agregar esta directiva en sus archivos .htaccess, pero asegúrese de desactivar nginx

La indexación de directorios está deshabilitada de forma predeterminada en nginx, por lo que no es necesario configurar nada.

Sin embargo, si se encuentra activado previamente por algún motivo puede desactivarlo abriendo el archivo de configuración nginx.conf y cambiando autoindex on a autoindex off.

### Activos afectados

| IP                                    | DOMINIO             | PUERTO    | ÚLTIMO CHEQUEO   |
|---------------------------------------|---------------------|-----------|------------------|
| 2600:9000:203b:3600:12:45c0:****:**** | community.**em*.com | 443 / tcp | 29-01-2023 16:51 |
| 2600:9000:203b:c00:12:45c0:****:****  | community.**em*.com | 443 / tcp | 29-01-2023 16:52 |
| 216.239.**.**                         | gtm.**em*.com       | 80 / tcp  | 29-01-2023 17:04 |

| IP                   | DOMINIO             | PUERTO    | ÚLTIMO CHEQUEO   |
|----------------------|---------------------|-----------|------------------|
| 143.204.***.**       | community.**em*.com | 443 / tcp | 29-01-2023 16:50 |
| 216.239.**.**        | gtm.**em*.com       | 443 / tcp | 29-01-2023 17:05 |
| 216.239.**.**        | gtm.**em*.com       | 80 / tcp  | 29-01-2023 17:05 |
| 216.239.**.**        | gtm.**em*.com       | 443 / tcp | 29-01-2023 17:04 |
| 143.204.***.**       | community.**em*.com | 443 / tcp | 29-01-2023 16:51 |
| 143.204.***.**       | community.**em*.com | 443 / tcp | 29-01-2023 16:51 |
| 216.239.**.**        | gtm.**em*.com       | 443 / tcp | 28-01-2023 16:48 |
| 216.239.**.**        | gtm.**em*.com       | 443 / tcp | 28-01-2023 16:48 |
| 143.204.***.**       | community.**em*.com | 443 / tcp | 29-01-2023 16:50 |
| 2001:4860:4802:**.** | gtm.**em*.com       | 443 / tcp | 29-01-2023 16:50 |

## Protección de cabeceras contra Clickjacking deshabilitada

### Descripción detallada



Las cabeceras HTTP X-Frame-Options se pueden usar para indicar si un navegador debe representar una página web en un tag <frame>, <iframe>, <embed> u <object>. Los sitios web suelen usarlo para evitar ataques de clickjacking, asegurándose así que su contenido no esté incrustado en otros sitios potencialmente maliciosos.

Clickjacking es un atacante que emplea el uso de múltiples capas transparentes u opacas para engañar a un usuario para que haga clic en un botón o enlace en otra página de la que el usuario tenía la intención de hacer clic. En estos ataques, el atacante está “secuestrando” los clics destinados a su página y dirigiéndolos a otra página, probablemente propiedad de otra aplicación, dominio o ambos.

Usando una técnica similar, también se pueden secuestrar las pulsaciones de teclas. Con una combinación cuidadosamente elaborada de hojas de estilo, iframes y cuadros de texto, se puede hacer creer a un usuario que está escribiendo la contraseña en su correo electrónico o cuenta bancaria, pero en su lugar está escribiendo en un marco invisible controlado por el atacante.

La seguridad de esta cabecera se proporciona sólo si el usuario accede desde un navegador que admita X-Frame-Options. Actualmente la mayoría de los navegadores lo soportan.

### Recomendacion



Se recomienda configurar el servidor siempre que sea posible para devolver cabeceras HTTP x-frame-options en sus respuestas para evitar ataques de tipo Clickjacking. Uno de los valores recomendados por defecto para esta cabecera es x-frame-options: SAMEORIGIN donde se informa al navegador del usuario que se permite el uso de frames siempre y cuando pertenezcan al mismo origen del dominio principal de la web solicitada.

### Activos afectados

| IP            | DOMINIO       | PUERTO    | ÚLTIMO CHEQUEO   |
|---------------|---------------|-----------|------------------|
| 216.239.**.** | gtm.**em*.com | 80 / tcp  | 29-01-2023 17:06 |
| 216.239.**.** | gtm.**em*.com | 443 / tcp | 29-01-2023 17:05 |
| 216.239.**.** | gtm.**em*.com | 80 / tcp  | 29-01-2023 17:05 |
| 216.239.**.** | gtm.**em*.com | 443 / tcp | 29-01-2023 17:06 |

| IP                                   | DOMINIO                        | PUERTO    | ÚLTIMO CHEQUEO   |
|--------------------------------------|--------------------------------|-----------|------------------|
| 2001:4860:4802:^^::^^                | gtm.**em*.com                  | 80 / tcp  | 29-01-2023 17:06 |
| 2001:4860:4802:^^::^^                | gtm.**em*.com                  | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:^^::^^                | gtm.**em*.com                  | 80 / tcp  | 29-01-2023 17:06 |
| 2001:4860:4802:^^::^^                | gtm.**em*.com                  | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:^^::^^                | gtm.**em*.com                  | 80 / tcp  | 29-01-2023 17:06 |
| 2001:4860:4802:^^::^^                | gtm.**em*.com                  | 443 / tcp | 29-01-2023 17:06 |
| 52.215.**.**                         | status.**em*.com               | 80 / tcp  | 29-01-2023 17:06 |
| 52.215.**.**                         | status.**em*.com               | 443 / tcp | 29-01-2023 17:06 |
| 138.197.**.**                        | rd-bounce.**em*.com            | 80 / tcp  | 29-01-2023 17:06 |
| 143.204.**.**                        | community.**em*.com            | 443 / tcp | 29-01-2023 16:50 |
| 143.204.**.**                        | community.**em*.com            | 443 / tcp | 29-01-2023 16:50 |
| 143.204.**.**                        | community.**em*.com            | 443 / tcp | 29-01-2023 16:50 |
| 143.204.**.**                        | community.**em*.com            | 443 / tcp | 29-01-2023 16:51 |
| 104.16.**.**                         | intellectualproperty.**em*.com | 443 / tcp | 29-01-2023 16:57 |
| 104.16.**.**                         | intellectualproperty.**em*.com | 443 / tcp | 29-01-2023 16:58 |
| 13.224.**.**                         | staging.community.**em*.com    | 443 / tcp | 29-01-2023 16:57 |
| 13.224.**.**                         | staging.community.**em*.com    | 80 / tcp  | 29-01-2023 16:56 |
| 13.224.**.**                         | staging.community.**em*.com    | 443 / tcp | 29-01-2023 16:57 |
| 13.224.**.**                         | staging.community.**em*.com    | 80 / tcp  | 29-01-2023 16:56 |
| 13.224.**.**                         | staging.community.**em*.com    | 443 / tcp | 29-01-2023 16:57 |
| 2600:9000:2133:4800:a:d537:****:**** | staging.community.**em*.com    | 80 / tcp  | 29-01-2023 16:57 |
| 2600:9000:2133:4800:a:d537:****:**** | staging.community.**em*.com    | 443 / tcp | 29-01-2023 16:57 |
| 2600:9000:2133:1200:a:d537:****:**** | staging.community.**em*.com    | 80 / tcp  | 28-01-2023 16:49 |
| 2600:9000:2133:1200:a:d537:****:**** | staging.community.**em*.com    | 443 / tcp | 28-01-2023 16:50 |

## Configuración insegura de HSTS

### Descripción detallada



HTTP Strict Transport Security (también llamado HSTS) es una mejora de seguridad opcional que especifica una aplicación web mediante el uso de un encabezado de respuesta específico. Una vez que un navegador compatible recibe este encabezado, ese navegador evitará que se envíen comunicaciones a través de HTTP al dominio especificado y, en su lugar, enviará todas las comunicaciones a través de HTTPS.

La especificación fue publicada a finales de 2012 como RFC 6797 (HTTP Strict Transport Security (HSTS)) por el IETF.

Ejemplos de cabecera:

Ejemplo usando una edad máxima larga (1 año = 31536000 segundos). Este ejemplo puede suponer un riesgo ya que no incluye la directiva 'includeSubDomains': `Strict-Transport-Security: max-age=31536000`

El siguiente ejemplo es útil si todos los subdominios presentes y futuros usarán HTTPS. Esta es una opción más segura pero bloqueará el acceso a ciertas páginas que se desee que solo se sirvan a través de HTTP:

`Strict-Transport-Security: max-age=31536000; includeSubDomains`

Este ejemplo es útil si todos los subdominios presentes y futuros serán HTTPS. En este ejemplo, establecemos una edad máxima muy corta en caso de errores durante el lanzamiento inicial:

`Strict-Transport-Security: max-age=86400; includeSubDomains`

### Recomendación



Si el propietario del sitio desea que su dominio se incluya en la lista de precarga de HSTS mantenida por Chrome (y utilizada por Firefox y Safari), utilice el encabezado 'preload'.

Es importante recalcar que usar la directiva 'preload' puede tener CONSECUENCIAS PERMANENTES y llegar a impedir que los usuarios accedan a la web y a cualquiera de sus subdominios si en algún momento se necesita volver a usar HTTP. Lea los detalles de la eliminación de la lista (<https://hstspreload.org/#removal>) antes de enviar la cabecera 'preload'.

Ejemplo de cabecera:

`Strict-Transport-Security: max-age=31536000; includeSubDomains; preload`

### Activos afectados



| IP                      | DOMINIO                     | PUERTO    | ÚLTIMO CHEQUEO   |
|-------------------------|-----------------------------|-----------|------------------|
| 216.239.**.**           | gtm.**em*.com               | 443 / tcp | 29-01-2023 17:05 |
| 216.239..**.**          | gtm.**em*.com               | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:**:**    | gtm.**em*.com               | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:**:**    | gtm.**em*.com               | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:**:**    | gtm.**em*.com               | 443 / tcp | 29-01-2023 17:06 |
| 143.204.**.**           | community.**em*.com         | 443 / tcp | 29-01-2023 16:50 |
| 143.204**.**            | community.**em*.com         | 443 / tcp | 29-01-2023 16:50 |
| 143.204.**.**           | community.**em*.com         | 443 / tcp | 29-01-2023 16:50 |
| 143.204.**.**           | community.**em*.com         | 443 / tcp | 29-01-2023 16:51 |
| 104.16.**.**            | **em*.com                   | 443 / tcp | 29-01-2023 17:00 |
| 104.16.**.**            | **em*.com                   | 443 / tcp | 29-01-2023 16:55 |
| 2606:4700::****:****    | **em*.com                   | 443 / tcp | 29-01-2023 17:08 |
| 2606:4700::****:****    | **em*.com                   | 443 / tcp | 29-01-2023 16:56 |
| 104.86.**.**            | experience.**em*.com        | 443 / tcp | 29-01-2023 16:48 |
| 104.86.**.**            | experience.**em*.com        | 443 / tcp | 29-01-2023 16:48 |
| 2a02:26f0:a1::****:**** | experience.**em*.com        | 443 / tcp | 29-01-2023 16:49 |
| 13.224.**.**            | staging.community.**em*.com | 443 / tcp | 29-01-2023 16:57 |
| 13.224.**.**            | staging.community.**em*.com | 443 / tcp | 29-01-2023 16:57 |
| 13.224.**.**            | staging.community.**em*.com | 443 / tcp | 29-01-2023 16:57 |

Cabecera de seguridad XSS deshabilitada

Descripción detallada



La cabecera de seguridad HTTP **X-XSS-Protection** es una capacidad que permite a los navegadores impedir la carga de una página web cuando detecta ataques del tipo Cross-Site (XSS (en-US)). Esta protección ofrece una capacidad de seguridad ante estos ataques a usuarios que usen navegadores antiguos que no soporten el uso de cabeceras de seguridad del tipo Content-Security-Policy.

CSP (Content-Security-Policy) hace posible que los administradores del servidor reduzcan o eliminen los vectores por los cuales XSS puede ocurrir al especificar los dominios que el navegador debe considerar como fuentes válidas de scripts ejecutables. Un navegador compatible con CSP solo ejecutará scripts cargados en archivos de origen recibidos de esos dominios permitidos, ignorando todos los demás scripts.

Recomendacion



Se recomienda usar esta cabecera y una configuración de la misma adecuadamente para proteger a los usuarios que puedan estar accediendo a la web usando navegadores antiguos que no soporten CSP (Content-Security-Policy).

Ejemplo de cabecera: **X-XSS-Protection: 1; mode=block**

Activos afectados

| IP                   | DOMINIO       | PUERTO    | ÚLTIMO CHEQUEO   |
|----------------------|---------------|-----------|------------------|
| 216.239.**.**        | gtm.**em*.com | 443 / tcp | 29-01-2023 17:05 |
| 216.239.**.**        | gtm.**em*.com | 80 / tcp  | 29-01-2023 17:05 |
| 216.239.**.**        | gtm.**em*.com | 80 / tcp  | 29-01-2023 17:06 |
| 216.239.**.**        | gtm.**em*.com | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:**:** | gtm.**em*.com | 80 / tcp  | 29-01-2023 17:06 |
| 2001:4860:4802:**:** | gtm.**em*.com | 443 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:**:** | gtm.**em*.com | 80 / tcp  | 29-01-2023 17:06 |

| IP                                    | DOMINIO                     | PUERTO    | ÚLTIMO CHEQUEO   |
|---------------------------------------|-----------------------------|-----------|------------------|
| 2600:9000:203b:cc00:12:45c0:****:**** | em*.com                     | 443 / tcp | 28-01-2023 16:48 |
| 2600:9000:203b:7000:12:45c0:****:**** | community.**em*.com         | 80 / tcp  | 29-01-2023 16:51 |
| 2600:9000:203b:7000:12:45c0:****:**** | community.**em*.com         | 443 / tcp | 29-01-2023 16:51 |
| 2600:9000:203b:c00:12:45c0:****:****  | community.**em*.com         | 80 / tcp  | 29-01-2023 16:51 |
| 2600:9000:203b:c00:12:45c0:****:****  | community.**em*.com         | 443 / tcp | 29-01-2023 16:52 |
| 13.224.***.**                         | mi.**em*.com                | 80 / tcp  | 29-01-2023 16:57 |
| 13.224.***.**                         | mi.**em*.com                | 443 / tcp | 29-01-2023 16:57 |
| 13.224.***.**                         | mi.**em*.com                | 80 / tcp  | 29-01-2023 16:57 |
| 13.224.***.**                         | mi.**em*.com                | 443 / tcp | 29-01-2023 16:58 |
| 13.224.***.***                        | mi.**em*.com                | 80 / tcp  | 29-01-2023 16:57 |
| 13.224.***.***                        | mi.**em*.com                | 443 / tcp | 29-01-2023 16:58 |
| 13.224.***.**                         | mi.**em*.com                | 80 / tcp  | 29-01-2023 16:48 |
| 13.224.***.**                         | mi.**em*.com                | 443 / tcp | 29-01-2023 16:49 |
| 151.101.**.***                        | webinars.**em*.com          | 80 / tcp  | 29-01-2023 16:52 |
| 151.101.**.***                        | webinars.**em*.com          | 443 / tcp | 29-01-2023 16:52 |
| 151.101.**.***                        | webinars.**em*.com          | 80 / tcp  | 29-01-2023 16:49 |
| 151.101.**.***                        | webinars.**em*.com          | 443 / tcp | 29-01-2023 16:49 |
| 13.224.***.**                         | staging.community.**em*.com | 80 / tcp  | 29-01-2023 16:52 |
| 13.224.***.**                         | staging.community.**em*.com | 443 / tcp | 29-01-2023 16:52 |
| 13.224.***.**                         | staging.community.**em*.com | 80 / tcp  | 29-01-2023 16:52 |

## Conexiones HTTP inseguras

### Descripción detallada



Implementar correctamente una capa de protección TLS proporciona una serie de beneficios de seguridad inmediatos:

- Confidencialidad: protección ante acceso al tráfico de usuarios legítimos no autorizados por parte de atacantes.
- Integridad: protección ante modificaciones del tráfico no autorizadas.
- Prevención ante ataques replay: protección ante reenvíos de tráfico por parte de un atacante.
- Autenticación: permite al usuario verificar que está conectado al servidor real.

Muchos otros protocolos utilizan TLS para proporcionar cifrado e integridad y se puede utilizar de diferentes formas.

### Recomendación



TLS debe usarse para todas las páginas, (no solo para aquellas que se consideran confidenciales) como la página de inicio de sesión. Si hay páginas que no imponen el uso de TLS, estas podrían darle al atacante la oportunidad de olfatear información confidencial como tokens de sesión o inyectar JavaScript malicioso en las respuestas para llevar a cabo otros ataques contra el usuario.

Para las aplicaciones de acceso público puede ser apropiado hacer que el servidor web escuche las conexiones HTTP no cifradas en el puerto 80 y luego redirigirlas inmediatamente con una redirección permanente (HTTP 301) para brindar una mejor experiencia a los usuarios que escriben manualmente el nombre de dominio. Esto debería ser compatible con el encabezado HTTP Strict Transport Security (HSTS) para evitar que accedan al sitio a través de HTTP en el futuro.

### Activos afectados

| IP                    | DOMINIO       | PUERTO   | ÚLTIMO CHEQUEO   |
|-----------------------|---------------|----------|------------------|
| 216.239.**.**         | gtm.**em*.com | 80 / tcp | 29-01-2023 17:05 |
| 216.239.**.**         | gtm.**em*.com | 80 / tcp | 29-01-2023 17:06 |
| 2001:4860:4802:**::** | gtm.**em*.com | 80 / tcp | 29-01-2023 17:06 |

## Cabecera HTTP de plataforma habilitada

### Descripción detallada



Se ha detectado una cabecera HTTP que ofrece información de forma inmediata sobre la plataforma software que soporta la aplicación. Esta información puede resultar muy útil para la ejecución remota de ataques automatizados o para ahorrar tiempo en la ejecución de ataques dirigidos. Algunos ejemplos de esta cabecera son: **PHP/5.5.9-1ubuntu4.5** or **ASP.NET**

Si bien es cierto que la técnica de obtener la información es muy básica (mirar el campo **X-Powered-By** en el encabezado de respuesta HTTP), la remediación también puede ofrecer ventajas con poco esfuerzo.

### Recomendación



Es posible deshabilitar fácilmente el envío de la cabecera 'X-Powered-By' mediante una configuración adecuada. También existen varias técnicas que permiten que un sitio web ofusque los encabezados HTTP.

### Activos afectados

| IP                                    | DOMINIO             | PUERTO    | ÚLTIMO CHEQUEO   |
|---------------------------------------|---------------------|-----------|------------------|
| 143.204.**.*                          | community.**em*.com | 443 / tcp | 29-01-2023 16:51 |
| 104.17.**.*                           | infom.**em*.com     | 443 / tcp | 29-01-2023 16:59 |
| 96.16.**.*                            | investors.**em*.com | 80 / tcp  | 29-01-2023 16:49 |
| 143.204.**.*                          | community.**em*.com | 80 / tcp  | 29-01-2023 16:50 |
| 96.16.**.*                            | investors.**em*.com | 443 / tcp | 29-01-2023 16:49 |
| 18.215.**.*                           | helpdesk.**em*.com  | 443 / tcp | 29-01-2023 16:58 |
| 216.239.**.*                          | gtm.**em*.com       | 80 / tcp  | 29-01-2023 17:05 |
| 2600:9000:203b:8800:12:45c0:****:**** | community.**em*.com | 80 / tcp  | 29-01-2023 16:50 |
| 96.16.**.*                            | investors.**em*.com | 80 / tcp  | 29-01-2023 16:49 |

## Cabecera HTTP Server detectada

### Descripción detallada



La cabecera **Server** contiene la información acerca del software usado por el servidor original encargado de la solicitud.

Cualquier información larga y detallada debe de ser evitada en las cabeceras **Server** ya que puede revelar detalles de implementación que pueden hacer (un poco) más fácil para los atacantes encontrar y explotar huecos de seguridad.

Ejemplo: **Server: Apache2.4.1 (Unix)**

### Recomendación



Es posible deshabilitar fácilmente el envío de la cabecera **Server** mediante una configuración adecuada. También existen varias técnicas que permiten que un sitio web ofusque los encabezados HTTP.

### Activos afectados

| IP                      | DOMINIO              | PUERTO    | ÚLTIMO CHEQUEO   |
|-------------------------|----------------------|-----------|------------------|
| 216.239.**.**           | gtm.**em*.com        | 80 / tcp  | 29-01-2023 17:05 |
| 96.16.**.**             | investors.**em*.com  | 80 / tcp  | 29-01-2023 16:49 |
| 96.16.**.**             | investors.**em*.com  | 443 / tcp | 29-01-2023 16:49 |
| 2a02:26f0:a1::****:**** | experience.**em*.com | 443 / tcp | 29-01-2023 16:49 |
| 96.16.**.**             | investors.**em*.com  | 80 / tcp  | 29-01-2023 16:49 |
| 96.16.**.**             | investors.**em*.com  | 443 / tcp | 29-01-2023 16:49 |
| 2a02:26f0:e8::****:**** | investors.**em*.com  | 80 / tcp  | 28-01-2023 16:49 |
| 2a02:26f0:e8::****:**** | investors.**em*.com  | 443 / tcp | 28-01-2023 16:48 |
| 216.239.**.**           | gtm.**em*.com        | 80 / tcp  | 29-01-2023 17:05 |

## Cifrado inseguro

### Descripción

La finalidad principal de esta categoría de pruebas es detectar cualquier configuración insegura que impida el correcto uso de capas de cifrado allí donde sea necesario usarlas. El cifrado de las comunicaciones es una de las capas más importantes en cuanto a asegurar la confidencialidad e integridad se refiere. Es habitual encontrar configuraciones obsoletas o incorrectas sobre los servicios encargados de establecer esta capa de cifrado.

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 4

Certificado próximo a caducar



### Recomendaciones

Se recomienda revisar siempre la correcta configuración de los servicios de cifrado con el fin de asegurar que se están protegiendo adecuadamente las comunicaciones y se aseguran los niveles de confidencialidad e integridad necesarios y esperados.

## Certificado próximo a caducar

### Descripción detallada



Los navegadores emitirán una advertencia cuando encuentren certificados caducados, certificados emitidos por CA que no son de confianza, y certificados cuyo nombre no coincide con el sitio al que deberían referirse.

### Recomendacion



Recuerde actualizar el certificado antes de 26 días (Feb 25 12:50:18 2023 GMT)

### Activos afectados

| IP                      | DOMINIO             | PUERTO    | ÚLTIMO CHEQUEO   |
|-------------------------|---------------------|-----------|------------------|
| 2a02:26f0:e8::****:**** | investors.**em*.com | 443 / tcp | 29-01-2023 16:49 |
| 2a02:26f0::****:****    | investors.**em*.com | 443 / tcp | 28-01-2023 16:48 |
| 96.16.**.***            | investors.**em*.com | 443 / tcp | 29-01-2023 16:49 |
| 96.16.**.***            | investors.**em*.com | 443 / tcp | 29-01-2023 16:49 |



Reputacion

Descripción

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 1

IP marcada como servidor de Spam



Recomendaciones

## IP marcada como servidor de Spam

### Descripción detallada



Se ha descubierto un activo de la organización en una lista negra basada en nombres DNS donde consta que se relaciona este activo con actividad similar a la de un servidor de SPAM u otro tipo de actividades asociadas al malware.

Muchos servidores de correo legítimos rechazarán conexiones de este elemento si están suscritos a DNSBL.

NOTA: Se debe tener en cuenta que estas listas pueden no estar actualizadas y la información debe ser verificada.

A continuación se muestran algunos detalles de la información obtenida sobre el activo de la organización en esta lista:

**IP:** 149.72.\*\*\*.\*\* listada en spam.dnsbl.sorbs.net.

**Descripción:** SORBS List of hosts that have been noted as sending spam/UCE/UBE to the admins of SORBS at any time, and not subsequently resolving the matter..

**Tipo:** spam. **Petición de borrado:** <http://www.sorbs.net/delisting/overview.shtml>

### Recomendación



Se recomienda verificar el correcto comportamiento del servidor y comprobar que no se esté enviado correos electrónicos de forma no controlada. En ocasiones, un actor malintencionado puede abusar de un servicio legítimo para enviar spam sin el conocimiento del propietario del activo.

### Activos afectados

| IP            | DOMINIO                       | PUERTO | ÚLTIMO CHEQUEO   |
|---------------|-------------------------------|--------|------------------|
| 149.72.***.** | o3608.abmail.alerts.**em*.com | ---    | 29-01-2023 17:09 |

Red

Descripción

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 1

No se ha detectado un cortafuegos (Firewall)



Recomendaciones

No se ha detectado un cortafuegos (Firewall).

Descripción detallada



Se ha detectado un activo que parece no estar detrás de un firewall o tiene una mala configuración.

Recomendacion



Se recomienda que todos los activos expuestos a Internet estén protegidos por un firewall con la configuración más restrictiva posible.

Activos afectados

| IP            | DOMINIO             | PUERTO | ÚLTIMO CHEQUEO   |
|---------------|---------------------|--------|------------------|
| 138.197.**.** | rd-bounce.**em*.com | ---    | 29-01-2023 17:06 |

## Problemas de seguridad en el DNS

### Descripción

Los servicios DNS son una parte fundamental de cualquier funcionalidad expuesta a internet y sin una configuración de seguridad adecuada puede facilitar que las amenazas en internet lo aprovechen para lanzar ataques principalmente contra los clientes que consuman los servicios ofrecidos por la organización. De igual forma, una configuración insegura puede facilitar el mal uso de la infraestructura de la organización por parte de agentes maliciosos situados en internet.

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 47

DNSSEC not enabled



### Recomendaciones

Se recomienda revisar la configuración de seguridad de los servicios DNS expuestos por la organización con la finalidad de reducir el riesgo de sufrir un mal uso de estos servicios y para asegurar los accesos de los clientes finales de la organización.

## DNSSEC not enabled

### Descripción detallada



#### Detectado servidor muestra los siguientes valores relacionados con DNSSEC

DNSSEC es la única forma de prevenir ataques de suplantación de DNS contra el servidor.

[Ataque de suplantación de DNS \(ES\)](#)

Los valores detectados son los siguientes:

mail.\*\*em\*.com. 298 IN CNAME ghs.google.com.mail.\*\*em\*.com. 298 IN CNAME ghs.google.com.

### Recomendación



#### Recomendable activar DNSSEC

Activar la validación mediante DNSSEC se protege a los usuarios a la propia compañía de posibles ataques de suplantación.

Al firmar sus zonas, se hace posible que otras personas verifiquen los datos de la zona DNS. A medida que más personas adoptan DNSSEC, Internet en su conjunto se vuelve más seguro para todos.

[FORTIFICACION DE UN SERVICIODNS \(ES\)](#)

[DNSSEC Guide from Bind \(EN\)](#)

### Activos afectados

| IP                     | DOMINIO              | PUERTO | ÚLTIMO CHEQUEO   |
|------------------------|----------------------|--------|------------------|
| 2a00:1450:4009:::***.* | mail.**em*.com       | ---    | 29-01-2023 17:07 |
| 142.250.***.**         | mail.**em*.com       | ---    | 29-01-2023 17:08 |
| 143.204.***.**         | community.**em*.com  | ---    | 29-01-2023 16:49 |
| 143.204.***.**         | community.**em*.com  | ---    | 29-01-2023 16:50 |
| 143.204.***.**         | community.**em*.com  | ---    | 29-01-2023 16:50 |
| 104.86.***.**          | experience.**em*.com | ---    | 29-01-2023 16:48 |

Protección de marca

Descripción

A continuación se muestra una visualización que informa sobre la proporción de activos afectados en cada una de las categorías. Cuanto mayor sea la proporción de activos afectados por ocurrencias de seguridad, al tratarse de un factor negativo, menos estrellas aparecen marcadas de amarillo. El valor numérico a la derecha indica la suma de ocurrencias detectadas en dicho módulo. Se recomienda que la organización reduzca la proporción de activos afectados por ocurrencias de seguridad, lo cual se refleja aumentando el número de estrellas amarillas. La proporción de activos afectados es un factor que afecta directamente al cálculo del score.

El número de activos afectados por al menos una ocurrencia de seguridad de esta categoría es: 4

Ataque por homografía sin referencias



Recomendaciones

## Ataque por homografía sin referencias

### Descripción detallada



Detectado un dominio con una homografía similar (IDN homograph attack) \*ûm\*.com  
.com(xn--d Whois:

Nombre: SafeNames Ltd.

Email: abuse@safenames.net

Dominio:

Fecha creación: 2021-02-04T15:59:48Z

Fecha de actualización: 2021-02-04T16:00:28Z

Fecha de caducidad: 2023-02-04T15:59:48Z

Servidores de Nombres (DNS): dns1.idp365.net,dns2.idp365.net,dns3.idp365.net

### Recomendacion



Denounces the domain in the email abuse@safenames.net

### Activos afectados

| IP                   | DOMINIO   | PUERTO | ÚLTIMO CHEQUEO   |
|----------------------|-----------|--------|------------------|
| 104.16.**.**         | **em*.com | ---    | 29-01-2023 16:55 |
| 2606:4700::****.**** | **em*.com | ---    | 29-01-2023 17:08 |
| 2606:4700::****.**** | **em*.com | ---    | 29-01-2023 16:56 |
| 104.16.**.**         | **em*.com | ---    | 29-01-2023 17:00 |



## Metodología

Es una solución que permite descubrir y monitorizar la superficie de ataque de los activos expuestos a internet para que las organizaciones puedan medir su nivel de riesgo ante ciberataques. Esto se realiza de forma automática y continua mediante una serie de comprobaciones pasivas que permiten detectar debilidades de los activos (IPs y dominios) expuestos a Internet.

Cuenta con una infraestructura desplegada en Internet que realiza millones de chequeos todos los días sobre elementos expuestos en la red. La solución dispone de algoritmos de descubrimiento de activos que permiten detectar sistemas no inventariados y elementos que puedan estar mantenidos por terceros pero que están relacionados con el cliente, combatiendo así el Shadow IT.

El criterio general para el calculo del riesgo es:

$$\text{Riesgo} = \text{Probabilidad} * \text{Impacto}$$

Los factores tenidos en cuenta para el cálculo de la **probabilidad** son:

- Skill Level. Capacidad técnica del atacante para aprovechar la vulnerabilidad.
- Oportunidad. Qué esfuerzo e inversión requiere explotar la vulnerabilidad
- Facilidad de detección de la vulnerabilidad
- Facilidad de explotación de la vulnerabilidad

Los factores tenidos en cuenta para el cálculo del **impacto** son:

- Afectación de la confidencialidad. Cuánta información puede verse afectada y la sensibilidad de dicha información.
- Pérdida de integridad. Cuánta información puede verse afectada por pérdida o degradación.
- Afectación a la disponibilidad. En qué grado la vulnerabilidad puede afectar a la continuidad de la infraestructura que soporta el negocio.
- Potencial problema de reputación.
- Potencial incumplimiento de regulación o normativas.

| Overall Risk Severity |        |        |        |          |
|-----------------------|--------|--------|--------|----------|
| Impact                | HIGH   | Medium | High   | Critical |
|                       | MEDIUM | Low    | Medium | High     |
|                       | LOW    | Note   | Low    | Medium   |
|                       |        | LOW    | MEDIUM | HIGH     |
| Likelihood            |        |        |        |          |